

Phishing Email Triage — Part 1:

Phishing Email Triage — Option 1: User Reported Email Analysis

I analyzed a simulated phishing email, cross-referencing threat intelligence sources (AbuseIPDB, VirusTotal, URLScan.io) to confirm a typosquatted domain and Tor-based sender IP, then produced a formal SOC escalation ticket with IOC findings.

1. Overview

This engagement simulates one of the most common real-world Tier 1 SOC analyst tasks: triaging a suspicious email reported by an end user. The scenario follows the NIST Incident Response lifecycle, specifically the Detection and Analysis phase, and produces a formal escalation ticket ready for Tier 2 review.

An employee (john.smith@targetcompany.com) received an email purporting to be a Microsoft Security Alert and, rather than clicking the embedded link, forwarded the raw email to the SOC for investigation. The analyst's job is to determine whether the email is benign, suspicious, or confirmed phishing using command-line tools and web-based threat intelligence platforms — without ever clicking the link.

This scenario demonstrates the judgment a Tier 1 SOC analyst must exercise: correlating evidence across multiple independent sources, understanding why a mostly-clean URL scan result does not mean a URL is safe, and producing a structured, evidenced triage verdict before escalating.

2. NIST Incident Response Lifecycle — Phase Coverage

NIST Phase	Coverage in This Scenario
Preparation	Lab environment configured; Kali analyst workstation available with triage tools (dig, grep, curl, Firefox with access to AbuseIPDB, VirusTotal, URLScan.io)
Detection & Analysis	Full triage performed — header analysis, DNS investigation, IP reputation, URL analysis. Formal escalation ticket produced. This is the primary phase covered.
Containment, Eradication & Recovery	Recommended actions documented in escalation ticket for Tier 2 (block IP, block domains, search for other recipients). Not executed in this scenario — see Option 2.
Post-Incident Activity	Documented as portfolio write-up; IOCs recorded; gaps identified for future remediation.

3. Lab Architecture

Only one VM was required for this scenario. Ubuntu-victim was kept offline to preserve the 8 GB RAM ceiling.

Node	Role	Tools Used
ManKali-attacker	SOC analyst workstation	Terminal: grep, dig, curl Browser: AbuseIPDB, VirusTotal, URLScan.io
wazuh-manager	Reference only	Not directly used in Option 1 — relevant in Option 2 (clicked link scenario)
ubuntu-victim	Offline	Not required for email triage analysis

4. The Phishing Artifact

A realistic phishing email was crafted as a raw .eml file on the Kali analyst workstation, representing the forwarded email received from the reporting user. The artifact was constructed with the following characteristics:

- Sender display name impersonating Microsoft Security Team
- Typosquatted sending domain using a zero instead of the letter O (micros0ft-secure.com)
- SPF, DKIM, and DMARC all intentionally failing
- Sending IP routed through a Tor exit node
- Urgency-based social engineering body (unusual sign-in, 24-hour suspension threat)
- Embedded phishing URL on a throwaway .xyz domain with a victim-tracking token

```
mkdir ~/phishing-triage && cd ~/phishing-triage
cat > suspicious_email.eml << 'EOF'
From: "Microsoft Security Team" <security-alert@micros0ft-secure.com>
Authentication-Results: spf=fail (sender IP is 185.220.101.47)
  smtp.mailfrom=micros0ft-secure.com; dkim=none;
  dmarc=fail action=none header.from=micros0ft-secure.com
X-Originating-IP: 185.220.101.47
EOF
```

5. Triage Methodology

The triage followed a two-phase approach: command-line analysis first, then web-based threat intelligence. This reflects real SOC workflow — analysts work the raw data before reaching for external tools.

Phase 1 — Command-Line Header Analysis

Step 1: Extract sender address

```
grep "^From:" suspicious_email.eml
```

Result: From: "Microsoft Security Team" <security-alert@micros0ft-secure.com>

Finding: Display name impersonates Microsoft but the actual sending address uses a typosquatted domain. The zero replacing the letter O is a classic lookalike domain technique.

Step 2: Extract sending IP

```
grep "X-Originating-IP\|Received:" suspicious_email.eml
```

Result: X-Originating-IP: 185.220.101.47

Finding: The real sending IP embedded in the header — to be investigated in Phase 2 using threat intelligence tools.

Step 3: Check email authentication results

```
grep -i "authentication-results\|spf\|dkim\|dmarc" suspicious_email.eml
```

Result: spf=fail | dkim=none | dmarc=fail

Finding: All three email authentication mechanisms failed. In a properly configured mail environment with a strict DMARC policy, this email would have been rejected before the user ever saw it.

Step 4: Extract phishing URL

```
grep -o 'http[s]*://[^\"]*' suspicious_email.eml
```

Result: http://microsoft-account-verify.secure-login-portal.xyz/verify?token=a7f3k9

Finding: Throwaway .xyz TLD. The subdomain impersonates Microsoft. The token parameter (a7f3k9) is a victim tracking identifier.

Step 5: DNS investigation of the sending domain

```
dig micros0ft-secure.com A
dig micros0ft-secure.com MX
dig micros0ft-secure.com TXT
```

Result: NXDOMAIN across all three record types — the domain does not exist in DNS and has no legitimate infrastructure behind it.

Step 6: Confirm Tor exit node via Tor Project published list

```
curl https://check.torproject.org/torbulkexitlist | grep 185.220.101.47
```

Result: 185.220.101.47 confirmed in the Tor Project's own bulk exit node list — the strongest possible confirmation, direct from the authoritative source.

Phase 2 — Web-Based Threat Intelligence

AbuseIPDB — IP Reputation Check

Field	Value	Significance
Confidence of Abuse	100%	Maximum possible score
Times Reported	6,776	Extensively documented malicious history
ISP	Network for Tor-Exit traffic	Confirms Tor exit node classification
Hostname	tor-exit-47.for-privacy.net	Explicitly named as Tor exit node

VirusTotal — IP and URL Cross-Reference

- IP 185.220.101.47: 14/91 vendors flagged as malicious or phishing. Tor tag independently confirmed.
- Phishing URL: 1/92 malicious (Webroot), 1 suspicious (Forcepoint). Mostly-clean result is expected for a newly registered young domain — does not indicate safety. Triage verdict is based on totality of evidence, not any single tool.

URLScan.io — Sandbox URL Visit

Result: HTTP 400 — DNS Error. Domain offline — likely taken down by registrar following abuse reports. Does not change the triage verdict.

6. IOC Summary

Type	Value	Verdict	Source
Sender domain	micros0ft-secure.com	Malicious — typosquatting	Header analysis
Sending IP	185.220.101.47	Malicious — Tor exit node	AbuseIPDB / VirusTotal / Tor Project

Type	Value	Verdict	Source
Phishing domain	secure-login-portal.xyz	Malicious	VirusTotal / URLScan.io
Phishing URL	http://microsoft-account-verify.secure-login-portal.xyz/verify?token=a7f3k9	Malicious	VirusTotal / URLScan.io
Tracking token	a7f3k9	Suspicious — victim tracking	URL analysis
Email mailer	PHPMailer 6.1.8	Informational	Header analysis

7. Formal Tier 1 Escalation Ticket

The following is the structured triage report produced at the conclusion of analysis, formatted as a SOC ticket for Tier 2 escalation.

SOC TICKET — TIER 1 TRIAGE REPORT (FULL)

Ticket ID: SOC-2026-0925-001
Date/Time Opened: 2026-09-25 11:00 CDT
Analyst: Sherman (Tier 1 SOC Analyst)
Priority: HIGH
Status: Escalating to Tier 2
Classification: CONFIRMED PHISHING

INCIDENT SUMMARY

A suspicious email was submitted by end user john.smith@targetcompany.com after the user identified it as potentially malicious and reported it to the SOC without clicking any links. The email purported to be a Microsoft Security Alert requiring immediate account verification. Tier 1 triage has confirmed this is a phishing attempt.

AFFECTED USER

- Name: John Smith
- Email: john.smith@targetcompany.com
- Action taken: Reported without clicking — no active compromise suspected at this time

TECHNICAL FINDINGS

- Sender domain micros0ft-secure.com is typosquatted (zero replacing letter O). DNS returned NXDOMAIN across A, MX, and TXT records.
- Email authentication: SPF=FAIL, DKIM=none, DMARC=FAIL. Email cannot be verified as legitimate.
- Sending IP 185.220.101.47 confirmed as Tor exit node via three independent sources: Tor Project bulk list (CLI), AbuseIPDB (100% confidence, 6,776 reports), VirusTotal (14/91 vendors malicious).
- Phishing URL http://microsoft-account-verify.secure-login-portal.xyz/verify?token=a7f3k9 hosted on throwaway .xyz domain. Domain now offline. Tracking token a7f3k9 indicates victim-specific delivery.

TIMELINE

Time (UTC)	Event
2026-09-24 03:47:12	Email sent from 185.220.101.47 via Tor network
2026-09-24 03:47:15	Email received by targetcompany mail gateway
2026-09-25 10:49	User reported email to SOC without clicking
2026-09-25 11:00	Tier 1 triage initiated
2026-09-25 11:06	Header analysis complete — IOCs identified
2026-09-25 11:09	DNS investigation complete — NXDOMAIN confirmed
2026-09-25 11:12	Tor exit node confirmed via CLI and AbuseIPDB
2026-09-25 11:20	VirusTotal checks complete
2026-09-25 11:34	URLScan.io — domain offline confirmed
2026-09-25 11:40	Triage complete — escalating to Tier 2

TIER 1 VERDICT

CONFIRMED PHISHING. All indicators consistently point to a credential-harvesting phishing campaign impersonating Microsoft. User did not click the link — no active compromise at this time.

RECOMMENDED TIER 2 ACTIONS

- Search mail gateway logs for other recipients of this campaign (tracking token a7f3k9 suggests targeted delivery)
- Block 185.220.101.47 at email gateway and perimeter firewall
- Block microsoft-secure.com and secure-login-portal.xyz at DNS and proxy layer
- Search endpoint and proxy logs for any connections to secure-login-portal.xyz from internal hosts
- Issue security awareness advisory if additional recipients are found
- Submit IOCs to threat intelligence platform for tracking

8. MITRE ATT&CK Mapping

Tactic	Technique	Detail
Initial Access	T1566.001 — Spearphishing Link	Phishing email with embedded credential-harvesting URL targeting a specific user
Defense Evasion	T1036 — Masquerading	Typosquatted domain impersonating Microsoft to bypass casual inspection
Defense Evasion	T1665 — Hide Infrastructure	Tor exit node used to anonymize the sending IP
Credential Access	T1056 — Input Capture (attempted)	Phishing page designed to harvest Microsoft credentials — domain offline at time of analysis

9. Skills Demonstrated

- Phishing email triage using both CLI tools (grep, dig, curl) and web-based threat intelligence platforms (AbuseIPDB, VirusTotal, URLScan.io)
- Email header analysis: reading authentication results (SPF, DKIM, DMARC), extracting sending IP, identifying typosquatted domains
- IP reputation investigation across three independent sources with cross-referencing judgment
- Threat intelligence judgment: correctly interpreting a mostly-clean URL scan as consistent with a live young-domain attack rather than evidence of safety
- Structured escalation documentation: formal Tier 1 triage ticket with IOC summary, timeline, verdict, and actionable Tier 2 recommendations
- MITRE ATT&CK mapping applied to a real-world phishing scenario

10. Next Steps

- Option 2: Clicked link scenario — simulate a user clicking the phishing URL, observe Suricata and Wazuh detection, run full NIST IR lifecycle including containment and recovery
- After both options: document lab coverage gaps (no real email gateway, no Windows victim, no EDR) as a separate findings section
- Continue Tier 2 scenarios: brute-force detection, privilege escalation, malware simulation (EICAR)

Appendix — Real-World Short-Form Escalation Ticket

Note: In a real SOC environment, structured ticket fields (timestamp, affected user, priority, ticket ID) are populated automatically by the platform (ServiceNow, Jira, Splunk SOAR, etc.). The analyst writes only the summary, IOCs, verdict, and recommended actions shown below. This one-pager represents what a Tier 1 analyst would actually type into a live SOC ticket.

SOC TICKET — TIER 1 ESCALATION (SHORT FORM)

Ticket ID: SOC-2026-0925-001
Priority: HIGH
Classification: CONFIRMED PHISHING
Affected User: john.smith@targetcompany.com
Analyst: Sherman (Tier 1)
Status: Escalating to Tier 2

SUMMARY

User reported a suspicious email impersonating Microsoft Security Team without clicking any links. Triage confirms this is a phishing attempt using a typosquatted domain, a Tor exit node as the sending IP, and a credential-harvesting URL on a throwaway .xyz domain. No active compromise suspected at this time.

IOCs

Type	Value	Verdict
Sender domain	micros0ft-secure.com	Malicious — typosquatting
Sending IP	185.220.101.47	Malicious — Tor exit node (AbuseIPDB 100%, 6,776 reports)
Phishing domain	secure-login-portal.xyz	Malicious — now offline
Phishing URL	http://microsoft-account-verify.secure-login-portal.xyz/verify?token=a7f3k9	Malicious
Tracking token	a7f3k9	Victim tracking identifier

EMAIL AUTHENTICATION

- SPF: FAIL — sending IP not authorized by domain
- DKIM: None — email not cryptographically signed
- DMARC: FAIL — combined SPF and DKIM failure

VERDICT

CONFIRMED PHISHING. All indicators consistent with a credential-harvesting campaign impersonating Microsoft. User did not click the link. No active compromise at this time.

RECOMMENDED TIER 2 ACTIONS

- Search mail gateway logs for other recipients (tracking token a7f3k9 suggests targeted delivery)
- Block 185.220.101.47 at email gateway and perimeter firewall
- Block micros0ft-secure.com and secure-login-portal.xyz at DNS and proxy layer
- Search endpoint and proxy logs for connections to secure-login-portal.xyz from internal hosts; issue security awareness advisory if additional recipients are found